# Seguretat Apache

Administració de servidors web

IES Daniel Blanxart

# Autenticació i control d’accés

El servei web incorpora mecanismes bàsics per verificar els usuaris que volen accedir a àrees restringides. Però, a més a més, la flexibilitat dels mòduls fa que es puguin afegir nous mecanismes que puguin sorgir més endavant tot i que no hagin estat desenvolupats per Apache



# Autenticació i control d’accés

Mecanismes de validació d’usuaris generals que permet el servidor web:

- **Autenticació bàsica amb fitxers**: el mecanisme més simple per implementar el control d’accés a recursos d’una seu web és utilitzar fitxers d’usuaris i grups propis del servidor. L’avantatge principal d’aquest mètode és la facilitat d’administració. L’inconvenient és que comporta una gestió diferenciada dels usuaris del servei web i dels del sistema.
- **Autenticació mitjançant PAM:** comprova el directori /etc/passwd, el LDAP, el Kerberos, les empremtes dactilars o el que calgui. Usar el lligam amb el mòdul del PAM és un bon mecanisme per validar els usuaris del servei web igual que es validen els usuaris del sistema.
- **Autenticació mitjançant LDAP:** El mòdul del LDAP permet passar la
- validació dels usuaris a l’encarregat de gestionar l’autenticació LDAP dels usuaris del sistema.



# Què és un Servidor LDAP?

Un servidor LDAP és un tipus de servidor que implementa el protocol LDAP (Lightweight Directory Access Protocol, o Protocol Lleuger d'Accés a Directoris).
LDAP és un protocol d'aplicació que s'utilitza per a consultar i modificar serveis de directori a través d'una xarxa.
Un servei de directori és un magatzem d'informació centralitzat i jeràrquic (com una guia telefònica o un catàleg d'organització) que emmagatzema dades sobre usuaris, grups, recursos de xarxa, polítiques de seguretat i altra informació rellevant.



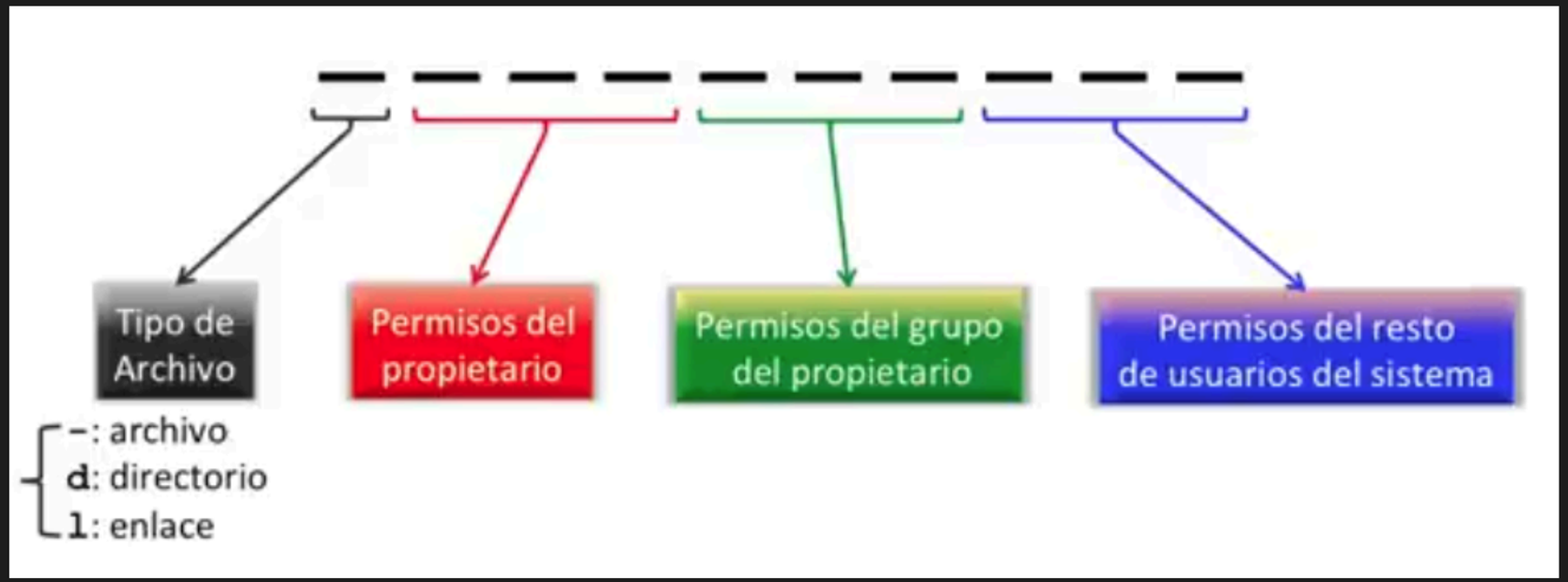
# Permisos per a Directoris

Es recomana el permís numèric 755 (rwxr-xr-x).

- Com s'interpreta:
  - 7 (rwx) per al Propietari: L'usuari propietari (p. ex., el vostre usuari o root) pot llegir, escriure i executar/travessar el directori.
  - 5 (r-x) per al Grup (Apache): Permet al grup d'Apache (www-data) llegir el contingut del directori i executar/travessar-lo per accedir als fitxers. Apache només necessita llegir i accedir.
  - 5 (r-x) per a Altres: Permet a altres usuaris llegir i accedir.



# Permisos per a Directoris



# Autenticació i Autorització



- **Autenticació:** el procés d'autenticació és el que determina si un usuari és qui diu ser.
- **Autorització**: un cop s'ha identificat un usuari (és qui diu ser), què pot fer?, a quins recursos pot accedir?, a quins no? Això és l'autorització: determinar els drets d'utilització dels recursos.




# Realm

- **Àrea d'Accés Restringit:** Designa un conjunt de pàgines, directoris o recursos dins d'un lloc web que estan protegits i requereixen que l'usuari s'autentiqui (introdueixi un nom d'usuari i contrasenya) per accedir-hi.
- **Domini d'Autenticació Compartida:** Totes les àrees que formen part del mateix Reialme comparteixen el mateix mecanisme d'autenticació i la mateixa base de dades d'usuaris i contrasenyes.



# Com Funciona

Quan un usuari intenta accedir a una pàgina protegida:

- El servidor detecta que la pàgina forma part d'un Realm.
- Si l'usuari no ha iniciat sessió (no està autenticat per a aquest Reialme), el servidor envia una sol·licitud d'autenticació.
- Un cop l'usuari s'autentica amb èxit per a un Realm, l'accés a qualsevol altra àrea assignada a aquest mateix Realm es concedeix automàticament sense haver de tornar a introduir les credencials.
- Si el lloc web té una segona àrea protegida amb un Realm diferent, l'usuari haurà d'autenticar-se de nou amb les credencials específiques d'aquest segon Realm.



# Web amb inici de nom d'usuari/contrasenya

Un error molt típic és confondre l'autenticació de servidor amb l'autenticació de programari que fan les seus webs. Quan un usuari es valida en un entorn web com per exemple Office o Google, no està usant l'autenticació amb el servidor web. Està usant un usuari i una contrasenya de l'empresa web a la qual es connecta i la gestió d'aquesta sessió d'usuari per consultar el seu correu es fa mitjançant la programació en les mateixes pàgines web que visita. Això no té res a veure amb el control d'accés al servidor que es tracta en aquest apartat.